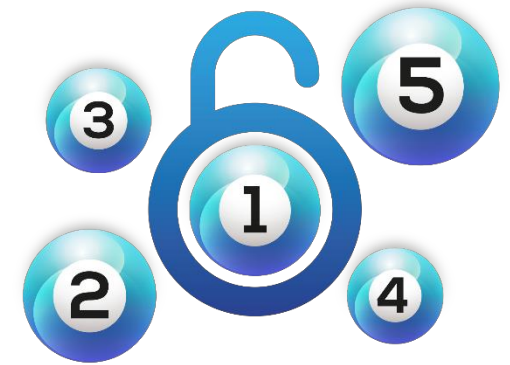


Backdooring the Lottery and Other Security Tales from Gaming



Gus Fritschie and Evan Teitelman

July 30, 2017



SeNet International Corporation

Don't Gamble with Security

Presentation Overview

1. Introductions
2. What has happened since 2011
3. Historical overview of security incidents in gaming
4. Eddie Tipton and the lottery
5. Russian slot attacks
6. Conclusion



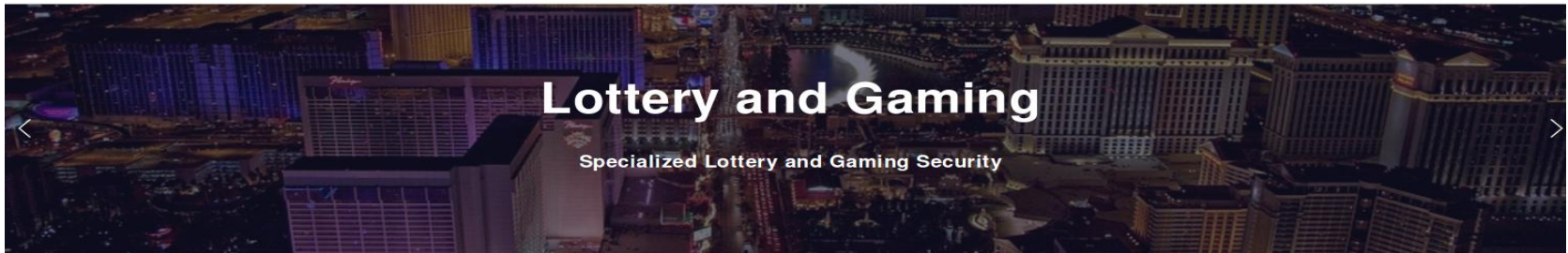


Who We Are – SeNet International



SeNet International Corporation
Technology Solutions You Can Trust

[HOME](#) [SERVICES](#) [CASE STUDIES](#) [RESOURCES](#) [CONTACT](#) [BLOG](#) [Q](#)



[About](#)
[History](#)
[News](#)
[Team](#)
[Contract Vehicles](#)

Forensics

Incident response and investigations

Assessment and Accreditation

From PCI to HIPAA

Security Engineering

Security operations support and monitoring

Training

Specialized IT security training

Social Engineering

Assessing user security awareness

Mobile Security

Android and iOS security assessments

We understand how important these are to your business. At SeNet International, our engineers are as capable of performing vulnerability assessments of multi-thousand host networks as they are at performing code review on large-scale applications.

Our methodology is grounded in 20 years of experience. Our clients range from Fortune 500 companies to government agencies, and from state lotteries to defense contractors.

Contact us [today](#).

Latest News

SeNet International

SeNet's CTO @gfritschie will be speaking at Defcon this year on "Backdooring the Lottery" and other security events in gaming.
6 days ago

SeNet International

SeNet's CTO @gfritschie will be attending the @EastCoastGaming conference starting tomorrow. #ECGC21

Who We Are – Gus Fritschie



@gfritschie

Gus Fritschie has been involved in information security since 2000. About 5 years ago (after his previous DEF CON presentation on iGaming security) he transitioned a significant portion of his practice into the gaming sector. Since then he has established himself and SeNet as the IT security leader in gaming. He has supported a number of clients across the gaming spectrum from iGaming operators, land-based casinos, gaming manufacturer, lotteries, tribal gaming, and daily fantasy sports.

Who We Are – Evan Teitelman

Evan works and lives in the Washington DC area. He is the founder of BlackArch Linux and specializes in reverse engineering and secure application development.

In his free time he enjoys hiking, climbing, and working on his van.





What this talk is and is not





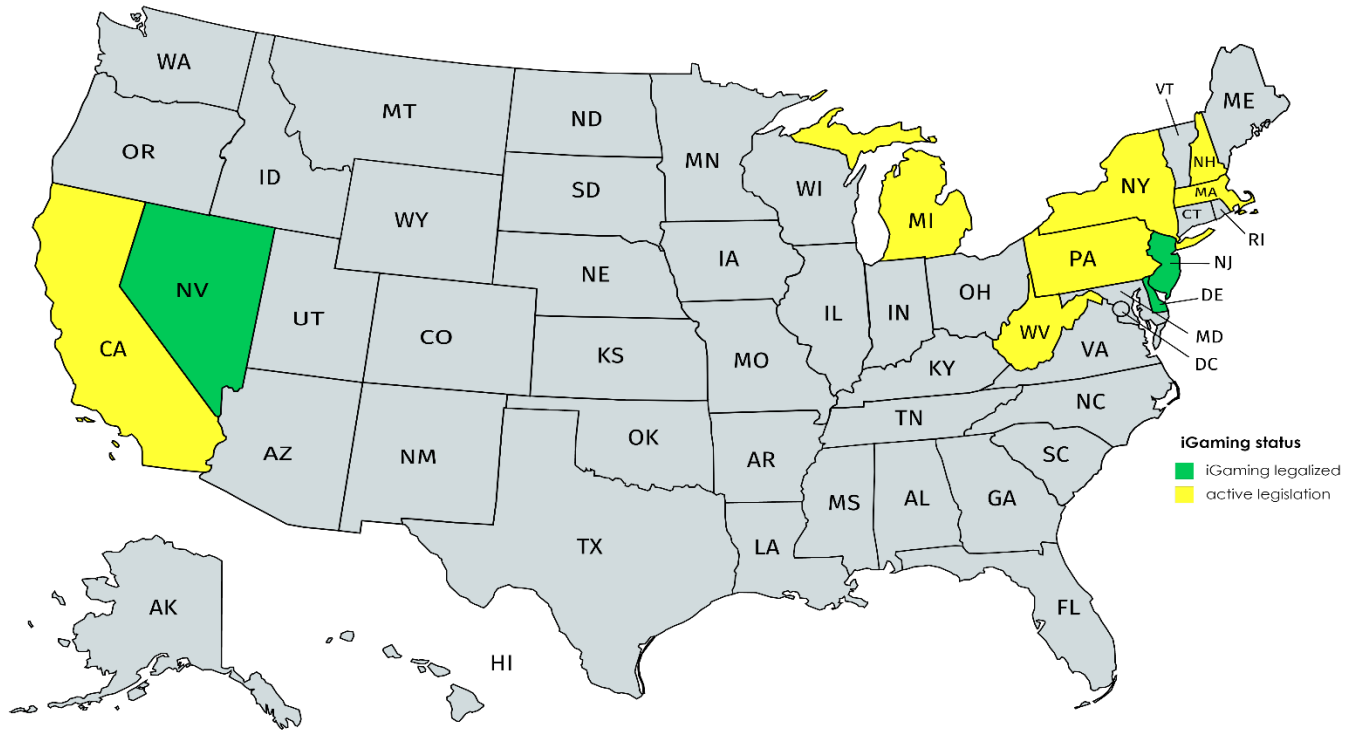
Getting F***** on the River

Gus Fritschie and Steve Witmer
with help from

Mike Wright, and JD Durick
August 6, 2011



SeNet International Corporation
e-Security – We Make It Practical



Created with mapchart.net ©

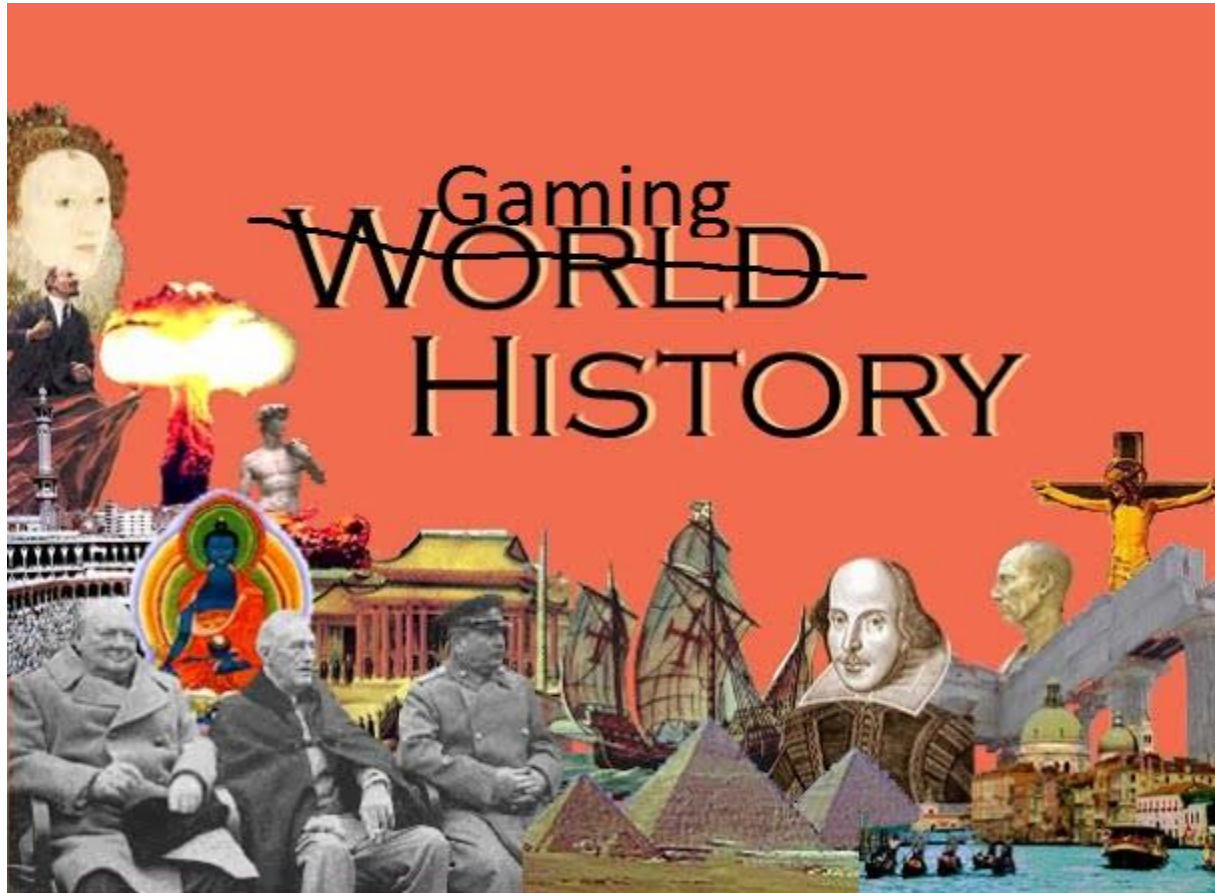
Highlighted Security Incidents in Gaming Since 2011

None of these will be discussed in detail but are listed to illustrate that this sector is not immune to these threats. Only a small sampling.

- Las Vegas Sands hack
- NJ iGaming DDOS attacks
- Affinity Gaming breach
- Hard Rock Hotel & Casino data breach
- Casino Rama Resort in Ontario
- Peppermill Resort Spa Casino in Reno credit card breach
- Weaknesses in Daily Fantasy Sports (DFS) protections

Sands website hacked





Early attacks against slot machines



Early attacks against slot machines (Cont.)

Shaved, fake coins and yo-yoing



Banknote validators



Early attacks against slot machines (Cont.)

Tommy Carmichael



Monkey Paw, a taut string attached to a bent metal rod. This rod was jammed into the machine via the air vent and was used to fish around for the switch that released the coin hopper. Once the switch was activated, money was released!



This contraption took advantage of the fact that new machines used optical sensors to detect the number of coins dispensed. By blinding the optical sensor, the Light Wand made it impossible for the machine to know how much money it was releasing. Therefore, a player equipped with a Light Wand only had to play until a small jackpot was hit; it was then a matter of inserting the wand and turning a small payout into a mountain of money.



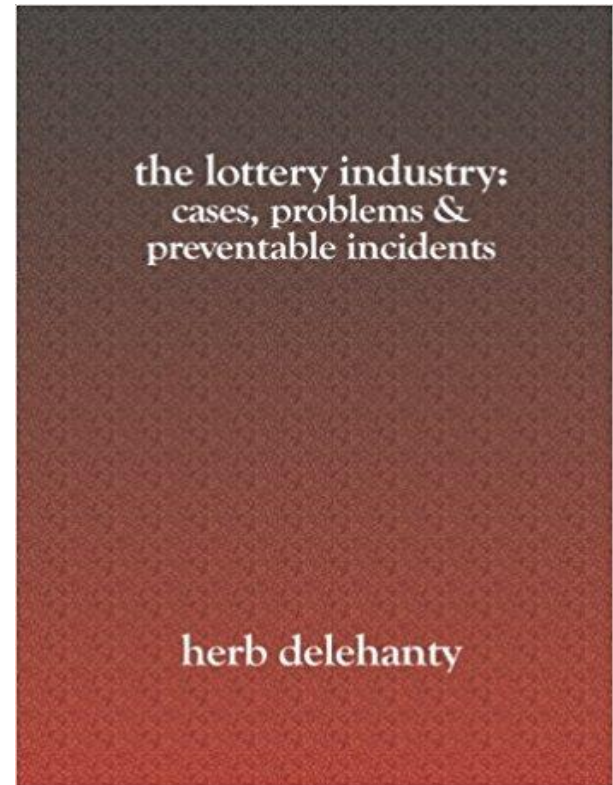
1980 Pennsylvania Lottery scandal

April 24th 1980 the lottery reaches its liability limits on the Daily Number (3-digit game) on 8 of the possible combinations of 6s and 4s (444, 446, 464, 644, 646, 664, 666)

Winning number was 666.

Later in the evening rumors surfacing that illegal bookmakers were not paying.

When watched in slow motion only the 4s and 6s ever move more than a few inches from the bottom, as the rest of the balls had been weighted.



Ron Harris attacks against slots and keno



Ronald Dale Harris is a computer programmer who worked for the Nevada Gaming Control Board in the early 1990s and was responsible for finding flaws and gaffes in software that runs computerized casino games. Harris took advantage of his expertise, reputation and access to source code to illegally modify certain slot machines to pay out large sums of money when a specific sequence and number of coins were inserted

Ron Harris attacks against slots and keno (Cont.)

Harris surreptitiously coded a hidden software switch -- tripped by inserting coins in a predetermined sequence -- that would trigger cash jackpots. After retooling more than 30 machines, Harris and accomplices made the rounds, walking away with hundreds of thousands of dollars.

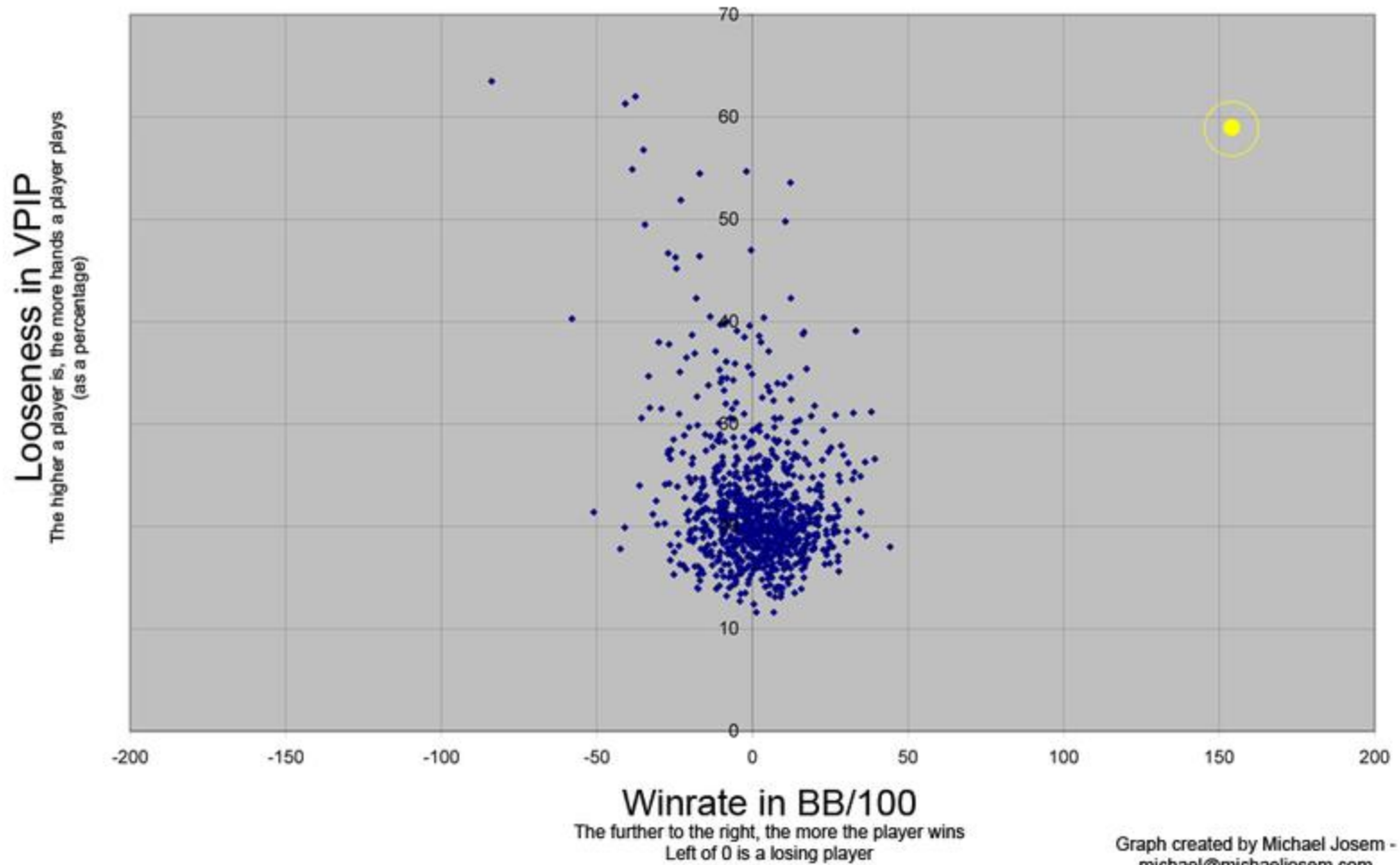


Ron Harris attacks against slots and keno (Cont.)



Harris shifted his focus to the probability game Keno, for which he developed a program that would determine which numbers the game's pseudorandom number generator would select beforehand. When Harris' accomplice, Reid Errol McNeal, attempted to redeem a high value winning keno ticket at Bally's Atlantic City Casino Hotel in Atlantic City, New Jersey, casino executives became suspicious of him and notified New Jersey gaming investigators. The investigation led authorities to Harris and after a trial was sentenced to seven years in prison. He was released from prison after serving two years and currently resides in Las Vegas.

Previous iGaming hacks/scandals





Eddie Tipton Hot Lotto RNG Rigging

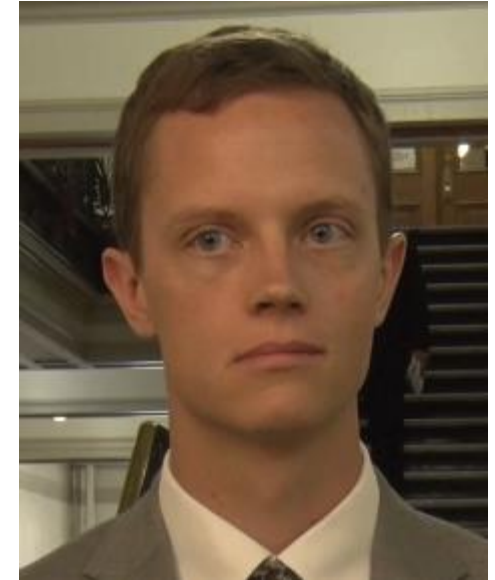
Eddie Tipton



Robert Rhodes



Tommy Tipton



Rob Sand – Iowa
Assistant Attorney
General (lead
prosecutor)

Lottery Fraud Case Involving a \$14.3 million prize!



Lottery ticket purchased at a QuikTrip near Interstate Highway 80 on Dec. 23, 2010.



Prize went unclaimed for almost a year, until Hexham Investments Trust, a mysterious company incorporated in Belize, tried to claim the prize through Crawford Shaw, a New York attorney, hours before the ticket was set to expire in 2011.

Lottery officials refused to release the prize because those behind the trust declined to give their identities, which is required under Iowa law.

Claim to prize was withdrawn in January 2012. At that time, Iowa Lottery officials asked the Iowa Attorney General's Office and Iowa DCI to investigate.

On Oct. 13, authorities received a tip from an out-of-state employee of the Multi-State Lottery Association that Tipton was the man in the video.

Investigators analyzed Tipton's cellphone records, which indicated he was in Des Moines when the ticket was purchased, according to the arrest report. They also discovered Tipton rented a silver 2007 Ford Edge on Dec. 22, which matched the vehicle of the buyer of the winning lottery ticket



Eddie was convicted in 2015 of two counts of fraud following a weeklong trial. One of the fraud charges accused Tipton of tampering with the nonprofit's computers to rig the draw, while the second accused him of participating in the ill-fated attempt to redeem the ticket in late 2011 that sparked an investigation.

He was sentenced to 10 years in prison, but has been out on bond pending appeal.

June 29, 2016 Tipton pleaded guilty to three felony charges in Iowa and Wisconsin. The other states where fraud occurred have agreed not to prosecute.

March 2003 – Eddie Tipton is hired at MUSL
November 23, 2005 – Colorado Lottery fraud
December 29, 2007 – Wisconsin Lottery fraud
December 29, 2010 – Kansas Lottery fraud
December 29, 2010 – Iowa Hot Lotto fraud
November 23, 2011 – Oklahoma Lottery fraud
January 15, 2015 – Eddie Tipton arrested
March 2015 – Rhodes was arrested on 2 counts of fraud
July 20, 2015 – Eddie Tipton Convicted
September 9, 2015 – Sentenced to 10 years, but free on bond pending appeal
October 2015 – New criminal charges filed related to 2005 and 2007 fraud
March 30, 2016 – Tommy Tipton charged
June 29th, 2017 – Eddie pleads guilty in Iowa

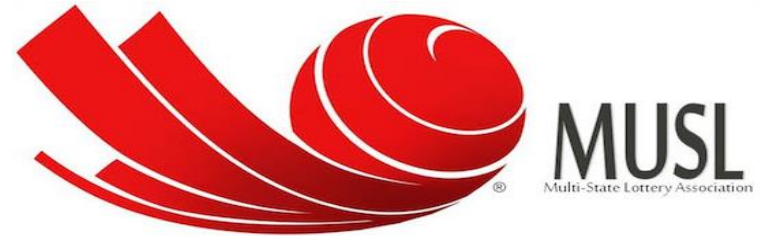
Steps to rig the lottery:

1. Become a lottery RNG developer
2. Write code to make the numbers predictable
3. Have your friends buy tickets with the winning numbers





How he Rigged the Lottery (really)

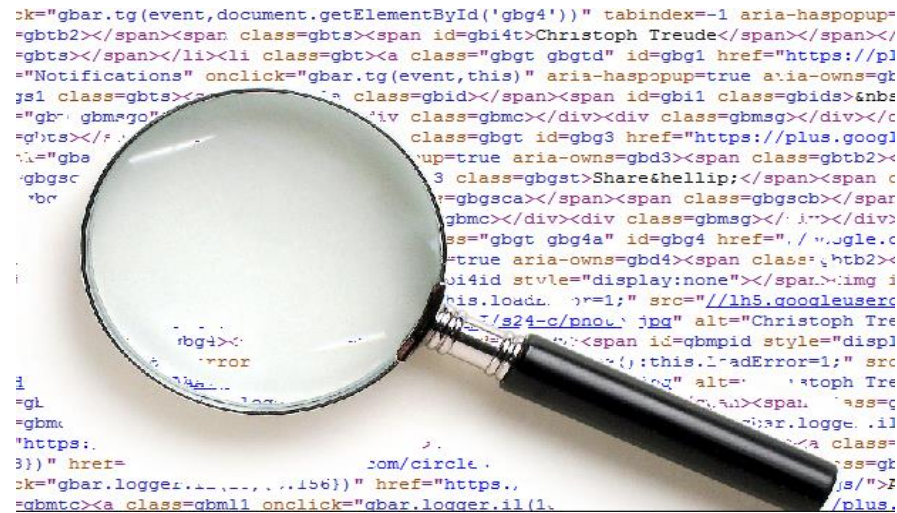


- In 2003 Eddie got a job as an RNG developer at MUSL
- While working there he wrote code which made the numbers predictable on three dates
- The source code and RNG binaries were certified by one of the major testing labs

How he rigged the lottery (cont.)

- In 2016 SeNet was contracted to perform imaging of one of the rigged lottery RNGs
- In 2016 after Eddie was convicted SeNet was given permission to review the RNG images
- Eddie didn't seem smart enough to write a rootkit which could change lottery numbers in memory
- So despite the official explanation (which he was convicted off of) for how he rigged the lottery I assumed he simply slipped some code into the RNG which rigged it...
- At this point we only had the binaries (no source code)

- The RNG consisted of an executable (QV.EXE) which contained the front-end material
- A DLL (QVRNG.DLL) which contained the PRNG
- And a DLL (AWRAND.DLL) which interfaced with the hardware RNG
- QVRNG.DLL was an obvious first choice for an RNG rigger
- So I looked at QVRNG.DLL first
- I briefly skimmed through all of the functions. One of them caught my eye...



```

.text:11005D8C      mov     [ebp+var_18C], eax
.text:11005D72      mov     [ebp+var_17C], eax
.text:11005D78      mov     [ebp+var_18C], eax
.text:11005D7E      mov     [ebp+var_118], 0Bh
.text:11005D88      call    esi ; __vbaVarMove
.text:11005D8A      cmp     dword ptr [edi+68h], 63h
.text:11005D8E      jg      loc_11006340
.text:11005D94      lea     eax, [ebp+var_C8]
.text:11005D9A      push    eax
.text:11005D9B      call    ds:rtcGetDateVar
.text:11005DA1      mov     ebx, ds:rtcDatePart
.text:11005DA7      push    1
.text:11005DA9      lea     ecx, [ebp+var_C8]
.text:11005DAF      push    1
.text:11005DB1      push    ecx
.text:11005DB2      lea     edx, [ebp+var_D8]
.text:11005DB8      push    offset dword_11002368
.text:11005DBD      push    edx
.text:11005DBE      call    ebx ; rtcDatePart
.text:11005DC0      lea     edx, [ebp+var_D8]
.text:11005DC6      lea     ecx, [ebp+var_74]
.text:11005DC9      call    esi ; __vbaVarMove
.text:11005DCB      lea     ecx, [ebp+var_C8]
.text:11005DD1      call    ds:__vbaFreeVar
.text:11005DD7      lea     eax, [ebp+var_C8]
.text:11005DDD      push    eax
.text:11005DDE      call    ds:rtcGetTimeVar
.text:11005DE4      push    1
.text:11005DE6      lea     ecx, [ebp+var_C8]
.text:11005DEC      push    1
.text:11005DEE      push    ecx
.text:11005DEF      lea     edx, [ebp+var_D8]
.text:11005DF5      push    offset dword_11002370
.text:11005DFA      push    edx
.text:11005DFB      call    ebx ; rtcDatePart
.text:11005DFD      lea     edx, [ebp+var_D8]
.text:11005E03      lea     ecx, [ebp+var_A4]
.text:11005E09      call    esi ; __vbaVarMove
.text:11005E0B      lea     ecx, [ebp+var_C8]
.text:11005E11      call    ds:__vbaFreeVar
.text:11005E17      mov     eax, 8002h
.text:11005E1C      lea     ecx, [ebp+var_118]
.text:11005E22      mov     [ebp+var_118], eax
.text:11005E28      mov     [ebp+var_128], eax

```


- At this point we also knew that all of the alleged illicit lottery wins related to the case were on two different days: November 23rd and December 29th (November 22nd and December 28th on leap years)
- So this function full of references to date checks and the PRNG internals was pretty suspicious
- Also the function was at the end of the binary (as if it had been tacked on to the end of a source file) which was suspicious
- At this point we were able to obtain the source code for the RNG
- Sure enough there were 25 functions in the source code and 26 functions in the binary

```
20
[para ../Lottery/wisconsin/comparison/original $ grep -e ' Function.*(' -e 'Sub.*(' cQRNG.cls | grep -v Declare
Private Sub Class_Initialize()
Private Sub Class_Terminate()
Private Sub setup_quantum()
Private Sub getSysInfo()
Private Sub getRunCount()
Public Function set_rndType(Value As Long)
Public Function get_rndType() As Long
Public Function set_bytes(Value As Long)
Public Function get_bytes() As Long
Public Function get_quantum() As Boolean
Public Function get_port() As Long
Public Function test_quantum() As String
Public Function qrnd(ByVal max As Long)
Public Function getNewSeed() As Long
Public Function getNumbers(ByVal seriesBegin As Long, ByVal seriesEnd As Long, ByVal numberToDraw As Long)
Public Function getNumbers_x(ByVal seriesBegin As Long, ByVal seriesEnd As Long, ByVal numberToDraw As Long)
Public Function getRawNumber(ByVal i_bytes As Long)
Private Function isValidSeries()
Private Function genrand_int31() As Long
Private Function genrand_int32() As Double 'unsigned long genrand()
Private Function genrand_int32SignedLong() As Long
Private Sub init_genrand(ByVal seed As Long)
Private Function uAdd(ByVal x As Long, ByVal y As Long) As Long
Private Function uDiv(ByVal x As Long, ByVal y As Long) As Long
Private Function uDiv2(ByVal x As Double, ByVal y As Long) As Double
Private Function uMult(ByVal x As Long, ByVal y As Long) As Long
para ../Lottery/wisconsin/comparison/original $
```

 Class_Terminate	.text	11002B90	00000070	00000024	00000000
 setup_quantum	.text	11002C00	00000B36	00000158	00000000
 getSysInfo	.text	11003740	000004BE	0000012C	00000000
 getRunCount	.text	11003C00	000000DC	00000040	00000000
 set_rndType	.text	11003CE0	000000A0	00000028	00000000
 get_rndType	.text	11003D80	000000A3	00000024	00000000
 set_bytes	.text	11003E30	00000092	00000028	00000000
 get_bytes	.text	11003ED0	00000067	00000024	00000000
 get_quantum	.text	11003F40	0000006A	00000024	00000000
 get_port	.text	11003FB0	00000067	00000024	00000000
 test_quantum	.text	11004020	00000332	00000064	00000000
 qrnd	.text	11004360	0000011D	00000060	00000000
 getNewSeed	.text	11004480	000000DC	00000054	00000000
 getNumbers	.text	11004560	00000526	000000F0	00000001
 getNumbers_x	.text	11004A90	000004BB	000000F0	00000001
 getRawNumber	.text	11004F50	00000141	00000070	00000000
 isValidSeries	.text	110050A0	000000E2	00000038	00000000
 genrand_int31	.text	11005190	00000055	00000024	00000000
 genrand_int32	.text	110051F0	00000070	00000010	00000000
 genrand_int32SignedLong	.text	11005260	00000494	000000BC	00000000
 init_genrand	.text	11005700	000000D0	00000034	00000000
 uAdd	.text	110057D0	00000090	00000010	00000001
 uDiv	.text	11005860	000000B0	00000010	00000001
 uDiv2	.text	11005910	0000009A	00000008	00000001
 uMult	.text	110059B0	000002F6	0000001C	00000001
 mystery_func	.text	11005CB0	0000077D	00000190	00000000

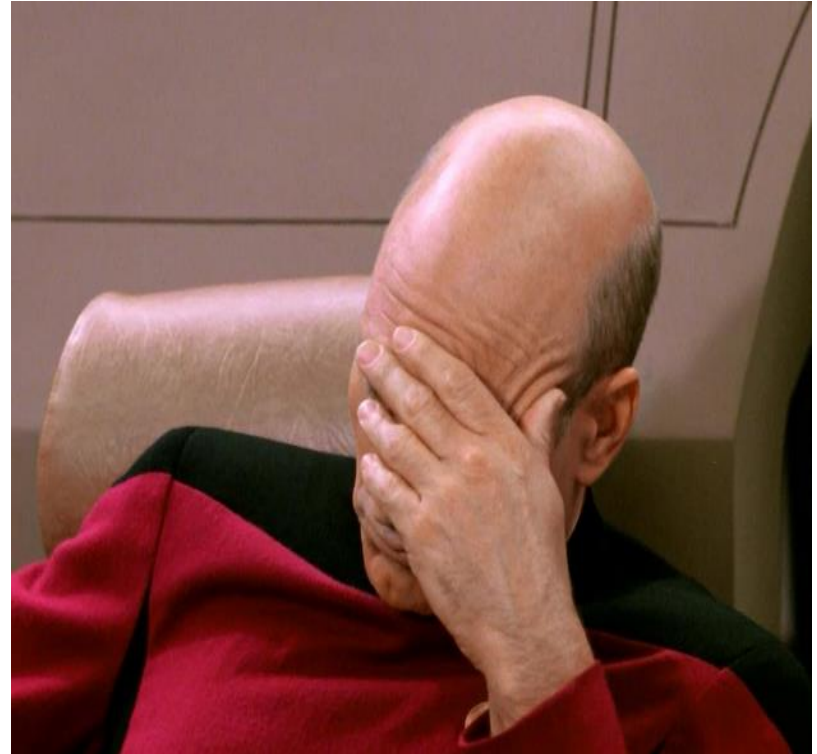
- The date calls corresponded to the two known dates of lottery rigging
- Plus one additional date: May 27th (May 26th on leap years)
- Additional conditions for the RNG rigging were identified and correlated with known illicit winnings
- For example, the RNG was only rigged on Wednesdays and Saturdays

```
103 ret = 0;
104 iter2 = 0;
105 iter3 = 0;
106 v42 = 0;
107 v40 = 0;
108 for_step = 11;
109 _vbaVarMove(&will_be_ret, &for_step);
110 if ( this->i_end <= 99 )
111 {
112     rtcGetDateVar(&Date);
113     rtcDatePart(&date_ret, "w", &Date, 1, 1);
114     _vbaVarMove(&day_of_week, &date_ret);
115     _vbaFreeVar(&Date);
116     rtcGetTimeVar(&Date);
117     rtcDatePart(&date_ret, "h", &Date, 1, 1);
118     _vbaVarMove(&hour_of_day, &date_ret);
119     _vbaFreeVar(&Date);
120     for_step = 32770;
121     for_end = 32770;
122     for_start = 32770;
123     begin = 20;
124     name_len = 4;
125     day_saturday = 7;
126     hour_over_20 = vbaVarCmpGt(&Date, &for_step, &hour_of_day);
127     day_is_wednesday = vbaVarCmpEq(&date_ret, &for_end, &day_of_week, hour_over_20);
128     day_is_saturday = vbaVarCmpEq(&foo, &for_start, &day_of_week, day_is_wednesday);
129     ret_4 = Or(&bar, day_is_saturday);
130     trigger = _vbaVarAnd(&v60, ret_4);
131     if ( _vbaBoolVarNull(trigger) )
132     {
133         rtcGetDateVar(&Date);
134         rtcDatePart(&date_ret, "y", &Date, 1, 1);
135         _vbaVarMove(&day_of_year, &date_ret);
136         _vbaFreeVar(&Date);
137         rtcGetDateVar(&Date);
138         rtcDatePart(&date_ret, "yyyy", &Date, 1, 1);
139         _vbaVarMove(&year, &date_ret);
140         _vbaFreeVar(&Date);
141         v49 = this->s_compName;
142         begin = 1;
143         for_step = 2;
144         name_len = _vbaLenBstr(v49);
145         for_end = 3;
146         day_saturday = 1;
147         for_start = 2;
148         for ( i = _vbaVarForInit(&iter1, &iter2, &iter3, &for_start, &for_end, &for_step);
149             i;
150             i = _vbaVarForNext(&iter1, &iter2, &iter3) )
151         {
152             v49 = &Date;
153             v65 = 1;
154             Date = 2;
155             begin = &this->s_compName;
156             for_step = 16392;
157             substr_start = vbaI4Var(&iter1);
158             rtcMidCharVar(&date_ret, &for_step, substr_start, v48);
159             chr = vbaStrVarVal(&v66, &date_ret);
160             day_saturday = rtcAnsIValueBstr(chr);
161             v46 = &name_total;
162             v45 = &for_start;
163             for_start = 3;
164             v10 = _vbaVarAdd(&foo);
165             _vbaVarMove(&name_total, v10);
166             _vbaFreeStr(&v66);
167             _vbaFreeVarList(2, &Date, &date_ret, v50, ret);
168         }
```


- The method by which the function reseeded the RNG with predictable numbers was identified
- Basically he just took various game parameters including the number of numbers per draw and the maximum and minimum numbers in the game and multiplied them together along with the number 39 and the summed ASCII values of the letters in the computer name. Then he took that and added it to the day of the year and added in the product of the number of times the RNG had run since the last reboot and the year.
- This number is then used to seed the PRNG.
- Then he drew a quantity of numbers from the RNG corresponding the quantity of numbers which had been drawn since the RNG last restarted. The last number drawn was then used to seed the PRNG a second time.

Why didn't certification work?

- The RNG was certified by one of the major testing labs
- The certification ran the output of the RNG through statistical tests to ensure unbiased results...
- But the output of the rigged RNG was statistically unbiased
- The lab performed an audit of the source code...



- Rigging the lottery on only three dates made it easier to identify illegal winnings
- Making numbers dependent on variables like the computer name and time of day meant he had to buy multiple tickets for each drawing
- The method of rigging the RNG could have been more discrete

How can this be prevented in the future?

- RNG source code should undergo in-depth third-party reviews
- The binaries (including updates) should be compiled and checked (e.g. via Bindiff) against the binaries provided by the RNG vendor
- The machine itself should be imaged and configured either by a third party or in a supervised manner

<https://www.wired.com/2017/02/russians-engineer-brilliant-slot-machine-cheat-casinos-no-fix/>

https://www.youtube.com/watch?v=W_vdoaKsP5Y (*Willy Allison World Game Protection Conference*)



Russian slot machine hacking (cont.)

- In 2009 Russia made majority of gambling illegal, this led to a number of slot machines being sold to whomever they could find
- By 2011 casinos in Europe were noticing suspicious payouts
- In June of 2014 in a casino in Missouri noticed unusual activity with some slot payouts, Missouri Gaming Commission was notified
- December of 2014 the same individuals were arrested back in Missouri
- 2016 some more were arrested and prosecuted in Singapore

How did they do this?

- Slot machine software was reversed engineered and a weakness discovered in the PRNG
- Phones were used to record about 24 spins
- Data uploaded and using video footage they were able calculate the pattern based on the slots PRNG
- Information is transmitted to a custom app with a listing of timing marks that cause the mobile to vibrate 0.25 seconds before the spin button should be pressed
- Not always successful, but the result is higher payout than expected

What casinos and operators can do to protect themselves



- Understand that compliance != security
- Similar to other verticals more budget needs to be spent on information security
- Operators need to question game manufacturers on their security controls

Current gaming regulations with security components

- Maryland Gaming Commission requires an annual IT Security Assessment be performed by an independent and approved 3rd party on an annual basis.
- New Jersey Division of Gaming Enforcement has written in their iGaming standard that a security assessment be performed once a year on the iGaming platforms. Also includes other requirements such as auditing, password complexity, etc...
- Various tribal Minimum Internal Controls (MICs), however, these are typically very high-level.
- Also your typical regulatory compliance standards (i.e. PCI)
- Often left up to the operator to determine what level of security is implemented.

While regulated iGaming has added additional controls there is still room from improvement (both from operators and regulators).

In our opinion a major risk exists in the code and SDLC process (this is an area that is not really examined by regulators).

With gaming (all formats) becoming more widely accepted across the United States it is important the operators and regulators works together to protect the integrity of the games.

